



only_web_no_api_user_auth

Site: <https://localhost:8443>

Generated on Fri, 1 May 2026 15:08:30

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	3
Low	4
Informational	6

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap. log file for details	38
Low	Warning		ZAP warnings logged - see the zap. log file for details	79
Info	Informational	http://localhost:8443	Percentage of responses with status code 4xx	100 %
Info	Informational	http://localhost:8443	Percentage of slow responses	72 %
Info	Informational	https://ajax.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://ajax.googleapis.com	Percentage of endpoints with content type text/javascript	100 %

Info	Informational	https://ajax.googleapis.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://ajax.googleapis.com	Count of total endpoints	2
Info	Informational	https://ajax.googleapis.com	Percentage of slow responses	100 %
Info	Informational	https://archive.mozilla.org	Percentage of responses with status code 2xx	100 %
Info	Informational	https://archive.mozilla.org	Percentage of endpoints with content type application /x-xpinstall	100 %
Info	Informational	https://archive.mozilla.org	Percentage of endpoints with method GET	100 %
Info	Informational	https://archive.mozilla.org	Count of total endpoints	1
Info	Informational	https://archive.mozilla.org	Percentage of slow responses	100 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content type application /javascript	50 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content type text /css	50 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints	100 %

			with method GET	
Info	Informational	https://cdn.jsdelivr.net	Count of total endpoints	4
Info	Informational	https://cdn.jsdelivr.net	Percentage of slow responses	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of endpoints with content type application /octet-stream	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Count of total endpoints	1
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of slow responses	100 %
Info	Informational	https://fonts.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://fonts.googleapis.com	Percentage of endpoints with content type text /css	100 %
Info	Informational	https://fonts.googleapis.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://fonts.googleapis.com	Count of total endpoints	1
Info	Informational	https://fonts.googleapis.com	Percentage of slow responses	100 %

Info	Informational	https://fonts.gstatic.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://fonts.gstatic.com	Percentage of endpoints with content type font /woff2	100 %
Info	Informational	https://fonts.gstatic.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://fonts.gstatic.com	Count of total endpoints	2
Info	Informational	https://fonts.gstatic.com	Percentage of slow responses	69 %
Info	Informational	https://localhost:8443	Percentage of responses with status code 2xx	31 %
Info	Informational	https://localhost:8443	Percentage of responses with status code 3xx	1 %
Info	Exceeded Low	https://localhost:8443	Percentage of responses with status code 4xx	38 %
Info	Exceeded Low	https://localhost:8443	Percentage of responses with status code 5xx	30 %
Info	Informational	https://localhost:8443	Percentage of endpoints with content type application /json	30 %
Info	Informational	https://localhost:8443	Percentage of endpoints with content type image /jpeg	14 %
			Percentage of endpoints	

Info	Informational	https://localhost:8443	with content type image/png	5 %
Info	Informational	https://localhost:8443	Percentage of endpoints with content type text/css	3 %
Info	Informational	https://localhost:8443	Percentage of endpoints with content type text/html	37 %
Info	Informational	https://localhost:8443	Percentage of endpoints with method GET	89 %
Info	Informational	https://localhost:8443	Percentage of endpoints with method POST	10 %
Info	Informational	https://localhost:8443	Count of total endpoints	56
Info	Exceeded Low	https://localhost:8443	Percentage of slow responses	29 %
Info	Informational	https://maps.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://maps.googleapis.com	Percentage of slow responses	82 %
Info	Informational	https://maps.gstatic.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://maps.gstatic.com	Percentage of slow responses	100 %
Info	Informational	https://places.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://places.googleapis.com	Percentage of slow responses	100 %

Info	Informational	https://use.fontawesome.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://use.fontawesome.com	Percentage of endpoints with content type font /woff2	50 %
Info	Informational	https://use.fontawesome.com	Percentage of endpoints with content type text /css	50 %
Info	Informational	https://use.fontawesome.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://use.fontawesome.com	Count of total endpoints	4
Info	Informational	https://use.fontawesome.com	Percentage of slow responses	98 %
Info	Informational	https://www.google.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://www.google.com	Percentage of slow responses	100 %

Alerts

Name	Risk Level	Number of Instances
Buffer Overflow	Medium	1
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Sub Resource Integrity Attribute Missing	Medium	Systemic
Application Error Disclosure	Low	27
Cookie without SameSite Attribute	Low	Systemic
Cross-Domain JavaScript Source File Inclusion	Low	Systemic
Information Disclosure - Debug Error Messages	Low	27
Authentication Request Identified	Informational	2
Information Disclosure - Sensitive Information in URL	Informational	1
Information Disclosure - Suspicious Comments	Informational	29
Modern Web Application	Informational	Systemic

Session Management Response Identified	Informational	18
User Agent Fuzzer	Informational	Systemic

Alert Detail

Medium	Buffer Overflow
Description	Buffer overflow errors are characterized by the overwriting of memory spaces of the background
URL	https://localhost:8443/admin-login?error
Node Name	https://localhost:8443/admin-login (error)
Method	GET
Attack	HBoakiUOxphCKFvpSljIUhAXNdEPFXSsuERuCXtLPoRIqmkgCXgqeaMCyguWnkbYayFpiYdiv
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
Instances	1
Solution	Rewrite the background program using proper return length checking. This will require a recomp
Reference	https://owasp.org/www-community/attacks/Buffer_overflow_attack
CWE Id	120
WASC Id	7
Plugin Id	30001

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://localhost:8443/packages
Node Name	https://localhost:8443/packages
Method	GET
Attack	
Evidence	
Other Info	
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register
Method	GET
Attack	
Evidence	
Other Info	
URL	https://localhost:8443/services

Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Sub Resource Integrity Attribute Missing
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	<link href="https://fonts.googleapis.com/css2?family=Jost:wght@500;600&family=Roboto&display=swap" rel="stylesheet">
Other Info	
Instances	Systemic
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Low	Application Error Disclosure
Description	This page contains an error/warning message that may disclose sensitive information like the lo produced the unhandled exception. This information can be used to launch further attacks again application. The alert could be a false positive if the error message is found inside a documenta
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET

Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin-login?error
Node Name	https://localhost:8443/admin-login (error)
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/cart?token=-5f12NU8-WU_e873jJgSTHmmdlWz6r7pUc2Wq2JhhanDtVYwqSR4ewMnAMSHq2TvLUmLkjFpLCVXp
Node Name	https://localhost:8443/cart (token)
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/cart/add
Node Name	https://localhost:8443/cart/add
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/checkout
Node Name	https://localhost:8443/checkout
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/css
Node Name	https://localhost:8443/css
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/favicon.ico

Node Name	https://localhost:8443/favicon.ico
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/images
Node Name	https://localhost:8443/images
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/images/default-guide.jpg
Node Name	https://localhost:8443/images/default-guide.jpg
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/index
Node Name	https://localhost:8443/index
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/login
Node Name	https://localhost:8443/login
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check
Method	GET
Attack	
Evidence	HTTP/1.1 500

Other Info	
URL	https://localhost:8443/logout
Node Name	https://localhost:8443/logout
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/review-user
Node Name	https://localhost:8443/review-user
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/robots.txt
Node Name	https://localhost:8443/robots.txt
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET

Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/sitemap.xml
Node Name	https://localhost:8443/sitemap.xml
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/tour-details
Node Name	https://localhost:8443/tour-details
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/tour-details/1
Node Name	https://localhost:8443/tour-details/1
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/tour-details/2
Node Name	https://localhost:8443/tour-details/2
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/tour-details/index.html
Node Name	https://localhost:8443/tour-details/index.html
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/tour-details/packages.html

Node Name	https://localhost:8443/tour-details/packages.html
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/user
Node Name	https://localhost:8443/user
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/user/1
Node Name	https://localhost:8443/user/1
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/user/1/image
Node Name	https://localhost:8443/user/1/image
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
Instances	27
Solution	Review the source code of this page. Implement custom error pages. Consider implementing a unique error reference/identifier to the client (browser) while logging the details on the server and sending them to the user.
Reference	
CWE Id	550
WASC Id	13
Plugin Id	90022

Low	Cookie without SameSite Attribute
Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	https://localhost:8443/admin-login
Node Name	https://localhost:8443/admin-login

Method	GET
Attack	
Evidence	Set-Cookie: JSESSIONID
Other Info	
URL	https://localhost:8443/cart/add/2
Node Name	https://localhost:8443/cart/add/2
Method	GET
Attack	
Evidence	Set-Cookie: JSESSIONID
Other Info	
Instances	Systemic
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	Cross-Domain JavaScript Source File Inclusion
Description	The page includes one or more script files from a third-party domain.
URL	https://localhost:8443/packages
Node Name	https://localhost:8443/packages
Method	GET
Attack	
Evidence	<script src="https://ajax.googleapis.com/ajax/libs/jquery/3.6.4/jquery.min.js"></script>
Other Info	
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	<script src="https://ajax.googleapis.com/ajax/libs/jquery/3.6.4/jquery.min.js"></script>
Other Info	
Instances	Systemic
Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
Reference	
CWE Id	829
WASC Id	15
Plugin Id	10017

Low	Information Disclosure - Debug Error Messages	
Description	The response appeared to contain common error messages returned by platforms such as ASP servers such as IIS and Apache. You can configure the list of common debug messages.	
URL	https://localhost:8443/	
Node Name	https://localhost:8443/	
Method	GET	
Attack		
Evidence	Internal Server Error	
Other Info		
URL	https://localhost:8443/admin-login?error	
Node Name	https://localhost:8443/admin-login (error)	
Method	GET	
Attack		
Evidence	Internal Server Error	
Other Info		
URL	https://localhost:8443/cart?token=-5f12NU8-WU_e873jJgSTHmmdlWZ6r7pUc2Wq2JhhanDtVYwqSR4ewMnAMSHq2TvLUmLkjEpLCVXp_	
Node Name	https://localhost:8443/cart (token)	
Method	GET	
Attack		
Evidence	Internal Server Error	
Other Info		
URL	https://localhost:8443/cart/add	
Node Name	https://localhost:8443/cart/add	
Method	GET	
Attack		
Evidence	Internal Server Error	
Other Info		
URL	https://localhost:8443/checkout	
Node Name	https://localhost:8443/checkout	
Method	GET	
Attack		
Evidence	Internal Server Error	
Other Info		
URL	https://localhost:8443/css	
Node		

Name	https://localhost:8443/css
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/favicon.ico
Node Name	https://localhost:8443/favicon.ico
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/images
Node Name	https://localhost:8443/images
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/images/default-guide.jpg
Node Name	https://localhost:8443/images/default-guide.jpg
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/index
Node Name	https://localhost:8443/index
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/login
Node Name	https://localhost:8443/login
Method	GET
Attack	
Evidence	Internal Server Error
Other	

Info	
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/logout
Node Name	https://localhost:8443/logout
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/review-user
Node Name	https://localhost:8443/review-user
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/robots.txt
Node Name	https://localhost:8443/robots.txt
Method	GET

Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/sitemap.xml
Node Name	https://localhost:8443/sitemap.xml
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/tour-details
Node Name	https://localhost:8443/tour-details
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/tour-details/1
Node Name	https://localhost:8443/tour-details/1
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/tour-details/2
Node Name	https://localhost:8443/tour-details/2
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/tour-details/index.html

Node Name	https://localhost:8443/tour-details/index.html
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/tour-details/packages.html
Node Name	https://localhost:8443/tour-details/packages.html
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/user
Node Name	https://localhost:8443/user
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/user/1
Node Name	https://localhost:8443/user/1
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/user/1/image
Node Name	https://localhost:8443/user/1/image
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
Instances	27
Solution	Disable debugging messages before pushing to production.
Reference	
CWE Id	1295
WASC Id	13
Plugin Id	10023

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,remember-me,username)
Method	POST
Attack	
Evidence	password
Other Info	userParam=username userValue=foo-bar@example.com passwordParam=password referer=https://localhost:8443/login csrfToken=_csrf
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,username)
Method	POST
Attack	
Evidence	password
Other Info	userParam=username userValue=foo-bar@example.com passwordParam=password referer=https://localhost:8443/admin-login?error csrfToken=_csrf
Instances	2
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Information Disclosure - Sensitive Information in URL
Description	The request appeared to contain sensitive information leaked in the URL. This can violate PCI and organizational compliance policies. You can configure the list of strings for this check to add or remove to your environment.
URL	https://localhost:8443/cart?token=-5f12NU8-WU_e873jJgSTHmmlLwZ6r7pUc2Wq2JhhanDtVYwqSR4ewMnAMSHq2TvLUmLkjFpLCVXp_
Node Name	https://localhost:8443/cart (token)
Method	GET
Attack	
Evidence	token
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern
Instances	1
Solution	Do not pass sensitive information in URIs.
Reference	
CWE Id	598
WASC Id	13
Plugin Id	10024

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	https://localhost:8443/profile
Node Name	https://localhost:8443/profile
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "// if user adds new password, old and confirm are required", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin-login
Node Name	https://localhost:8443/admin-login
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected 2 times, the first in likely comment: "<!-- admin login start -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin-login
Node Name	https://localhost:8443/admin-login
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 2 times, the first in likely comment: "<!-- regular user login start -->", see evidence field for the suspicious comment /snippet.
URL	https://localhost:8443/admin-login?error
Node Name	https://localhost:8443/admin-login (error)
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected 2 times, the first in likely comment: "<!-- admin login start -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin-login?error
Node Name	https://localhost:8443/admin-login (error)
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 2 times, the first in likely comment: "<!-- regular user login start -->", see evidence field for the suspicious comment /snippet.
URL	https://localhost:8443/cart

Node Name	https://localhost:8443/cart
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tries to visit /admin, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart
Node Name	https://localhost:8443/cart
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tries to visit user pages, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add
Node Name	https://localhost:8443/cart/add
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tries to visit /admin, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add
Node Name	https://localhost:8443/cart/add
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tries to visit user pages, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add/1
Node Name	https://localhost:8443/cart/add/1
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tries to visit /admin, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add/1
Node Name	https://localhost:8443/cart/add/1
Method	GET

Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tries to visit user pages, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add/2
Node Name	https://localhost:8443/cart/add/2
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tries to visit /admin, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add/2
Node Name	https://localhost:8443/cart/add/2
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tries to visit user pages, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/login
Node Name	https://localhost:8443/login
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected 2 times, the first in likely comment: "<!-- admin login redirect start -->", see evidence field for the suspicious comment /snippet.
URL	https://localhost:8443/profile
Node Name	https://localhost:8443/profile
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected 3 times, the first in likely comment: "<!-- only show button if user isnt admin -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/tour-details/1
Node Name	https://localhost:8443/tour-details/1
Method	GET
Attack	
Evidence	user

Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- Calls to action depend on whether the user is logged in. -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/tour-details/2
Node Name	https://localhost:8443/tour-details/2
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- Calls to action depend on whether the user is logged in. -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/contact
Node Name	https://localhost:8443/contact ()(_csrf)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tries to visit /admin, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/contact
Node Name	https://localhost:8443/contact ()(_csrf)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tries to visit user pages, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,remember-me,username)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tries to visit /admin, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,remember-me,username)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tries to visit user pages, this button is displayed -->", see evidence field for the suspicious comment/snippet.

URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,username)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tries to visit /admin, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,username)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tries to visit user pages, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/logout
Node Name	https://localhost:8443/logout ()(_csrf)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tries to visit /admin, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/logout
Node Name	https://localhost:8443/logout ()(_csrf)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tries to visit user pages, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,mainPhone,name,newPassword,oldPassword,secondaryPhone)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tries to visit /admin, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,mainPhone,name,newPassword,oldPassword,secondaryPhone)

Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tries to visit user pages, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register ()(_csrf,email,iAgree,imageFile,lastName,mainPhone,name,password,secondaryPhone)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tries to visit /admin, this button is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register ()(_csrf,email,iAgree,imageFile,lastName,mainPhone,name,password,secondaryPhone)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tries to visit user pages, this button is displayed -->", see evidence field for the suspicious comment/snippet.
Instances	29
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	https://localhost:8443/packages
Node Name	https://localhost:8443/packages
Method	GET
Attack	
Evidence	<i class="fab fa-twitter"></i>
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register
Method	GET

Attack	
Evidence	<i class="fab fa-twitter"></i>
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	<i class="fab fa-twitter"></i>
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
Instances	Systemic
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	https://localhost:8443
Node Name	https://localhost:8443
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/admin-login
Node Name	https://localhost:8443/admin-login
Method	GET

Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/booking-user
Node Name	https://localhost:8443/booking-user
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/cart/add/2
Node Name	https://localhost:8443/cart/add/2
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/login
Node Name	https://localhost:8443/login
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/profile
Node Name	https://localhost:8443/profile
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/review-user
Node Name	https://localhost:8443/review-user
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/services

Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/tour-details/1
Node Name	https://localhost:8443/tour-details/1
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/tour-details/2
Node Name	https://localhost:8443/tour-details/2
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,remember-me,username)
Method	POST
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,username)
Method	POST
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register ()(_csrf,email,iAgree,imageFile,lastName,mainPhone,name,password,secondaryPhone)
Method	POST
Attack	
Evidence	JSESSIONID

Other Info	cookie:JSESSIONID
URL	https://localhost:8443
Node Name	https://localhost:8443
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/login
Node Name	https://localhost:8443/login
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,username)
Method	POST
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
Instances	18
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Agent Fuzzer
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	https://localhost:8443/

Node Name	https://localhost:8443/
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Other Info	
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104